FIT2093 Assignment 2 – Semester 1, 2024 Submission Guidelines & Tasks

Guidelines Details

- **Deadline:** Assignment 2 submission is due **in Week 12** on **20 May 2024** at 09:30am Melbourne, Australia time (CL Campus) and **20 May 2024** at 09:30am Malaysia time (MA Campus). This Task is an individual (not group) work and it must be submitted by each student **individually**.
- **Submission Platform:** Electronic submission via the `Assignment 2 Submission' link on the Moodle Assessments page (an Ed announcement will be sent once the link is added).
- **Required Files:** Required data and numerical parameter files for the assignment will be available for download via the Moodle `Asg 2 Moodle Quiz' link.
- **Submission File Format:** Two PDF documents: one for Task 1 and one for Task 2. There will also be an interview in week 12 Applied Session.
- **Submission Page Limit:** Each submitted PDF document must be **at most 10 pages, excluding cover page and references**. Any screenshots that cannot fit in the main 10 pages can be placed in an Appendix (which does not count in the page limit).
- **Plagiarism:** It is an academic requirement that your submitted work be original. Zero marks will be awarded for the whole submission if there is any evidence of copying, collaboration, pasting from web sites, or copying from textbooks.
- **Use of Generative AI tools:** ChatGPT or other AI tools may be used for study purposes, to learn about your topic, and to develop your assignment. However, similar to citation requirements for other references, you must include a clear declaration of all generative AI tools used (e.g. ChatGPT, DALL-E, Grammarly, voice-to-text), how and where you have used them. Please follow the Monash guidelines on how to acknowledge the use of Generative AI.

Notes

- **For each question**, you need to answer **both** the computation result question **and** the explanation questions about your working process such as the source code or the commands you are using to solve the tasks.
- Note that if numbers in this assignment are specified in hexadecimal format, your written answer and many software packages expect hexadecimal numbers to be input a '0x' prefix (e.g. '0xa0b1c2d3') for indicating the hexadecimal format. For example, this prefix allows SageMath to interpret the value in hex.

Background

Multiple factor authentication, usually a combination of biometric and password authentication factors, is widely used today to verify the identity of a user attempting to access a system. After being verified, whether they are permitted to access certain resources in the system depends on the access control configured. This assignment is designed to improve your understanding of these topics and apply this understanding in a practical real world scenario.

Task 1 gives you the practical exercises on a two-factor authentication system while Task 2 is an access control exercise of how a network administrator can set the permissions to various users and user groups according to the system access control requirements.

Overview of the assignment

The assignment is worth 30% of your total unit mark. In **Task 1** of the assignment (weight: 15% of your unit mark), you are to demonstrate your understanding of biometric authentication and password authentication in an individual **Task 1 report file**.
For biometric authentication, you will study how the system parameters affect the authentication accuracy. For password authentication, you will use the UNIX password authentication and use an attack tool application, John the Ripper and the UNIX password hashing tools, to study the impacts of password hashing parameters on the difficulty of hacking the hashed password and the usability of the system.

In **Task 2** of the assignment (weight : 15% of your unit mark), you are given several practical tasks on the access control knowledge you acquired in the lectures and tutorials/labs. You are asked to create new groups and users, and then assign the users into appropriate user groups. You will also study how SUID is used to give special access rights to users running certain processes. Another **Task 2 report file** should capture your results and explanation and is worthy of 10% of unit mark. **You have to demonstrate configuration results of Task 2 during the in-class interview which is worth 5 marks of your unit mark.**

Two report files in pdf format are to be submitted via one submission link.
Your work in this assignment will be assessed based on your **Task 1 and Task 2 reports and your responses on Task 2 in an interview conducted with your TA during your Applied Session in Week 12.**

Assessment Details

Task	Rubric
Task 1a	7.5% ■ Method and answers (FAR and FRR) for each threshold (4%) ■ Explanation on the impact of the choice of threshold (3.5%)
Task 1b	7.5% ■ Results of the four hashed passwords including screen captures for both john and mkpasswd timing (0.375% x 8 = 3%) ■ Discussions on the different approaches (2.5%) and time estimates for dictionary search (1%) ■ Recommendations on the password hashing (1%)
Task 2	15% ■ Task 2a (2%: on creating users and user groups). ■ Task 2b (5%: 3% on configuration and 2% read the file by non-owner) ■ Task 2c (3%: configuration of the files) ■ Interview during Week 12 Applied Session (5%)

Assignment Details

Task 1 (15% of unit marks): Two-Factor Authentication System

Task 1a) (7.5% of unit marks): Biometric authentication

Using the sample testing results of a face recognition authentication system, you are asked to evaluate the security and usability of this system using the False Acceptance Rate (FAR) and False Rejection Rate (FRR) accuracy metrics, as discussed in the User Authentication lecture.

Instructions:

Consider the sample testing results obtained using a Face recognition software in **Table 1** and **Table 2**.

Table 1 contains the face recognition testing results using 10 images of a registered person "Ammie". For each of those 10 testing images, the table shows the similarity probability score when trying to log in to Ammie's account using the image for face recognition. Note that the similarity probability scores indicate how similar each of Ammie's 10 login images are to Ammie's registered image, when attempting to access her account 10 times. The higher the similarity probability score, the more similar the login and registered images are. The system lets a user log in if the similarity score is greater than some threshold value.

Table 2 contains the face recognition testing results using 10 images of an un-registered person "Brenda". For each of those 10 testing images, the table shows the similarity probability score when trying to log in 10 times to Ammie's account using Brenda's images for the face recognition.

Registered Person ("Ammie") Testing Image ID	Similarity Probability Score
1	0.985
2	0.971
3	0.984
4	0.977
5	0.996
6	0.999
7	0.968
8	0.956
9	0.935
10	0.990

Table 1. Results for Registered Person ("Ammie") Testing Images

Un-Registered Person (“Brenda”) Testing Image ID	Similarity Probability Score
1	0.923
2	0.922
3	0.930
4	0.940
5	0.955
6	0.937
7	0.963
8	0.909
9	0.982
10	0.943

Table 2. Results for Unregistered Person (“Brenda”) Testing Images

- For the testing data in Table 1 and Table 2, count the number of images falling in each of the four categories below.
    - **True Accept/Positive (TP):** The system correctly lets the real account owner log in (probability score above the threshold)
    - **False Reject/Negative (FN):** The system incorrectly denies access to the real account owner (probability score below the threshold)
    - **False Accept/Positive (FP):** The system incorrectly lets an impersonator log in (probability score above the threshold)
    - **True Reject/Negative (TN):** The system correctly denies access to an impersonator (probability score below the threshold)

- Based on the results in Table 1 and Table 2, Compute the FAR and FRR metrics for your testing images using the two different threshold settings of 0.95 and 0.97, respectively.

- In the Task 1a section of your report, include and explain your calculations of FAR and FRR with the two different threshold settings of 0.95 and 0.97, respectively. Finally, include an explanation of the impact of the choice of threshold on the security and usability of the authentication system.

Task 1b) (7.5% of unit marks): Password Authentication

In this task, you will attempt to hack some system passwords using John the Ripper (command **`john`**) and investigate how this time and the time to compute a single password hash depends on the hashing parameters. You can time the brute force password search process by using **`time john <password file>`**. You can also measure the time taken to compute a single password hash by **`SHA-512`** using command **`time mkpasswd -m sha-512 <password>`**. Note that you should use "`user time`" (time spent by CPU to execute the **`mkpasswd`** process, excluding kernel and other processes' CPU time) in your below computations.

For **MAC M1/M2 ONLY**, before attempting this task, uninstall the pre-installed John the Ripper and install a new version by the following commands:

```
cd ~
sudo apt purge -y john
sudo snap install john-the-ripper --classic
rm -rf ~/.john
cp /usr/share/john/password.lst .
```

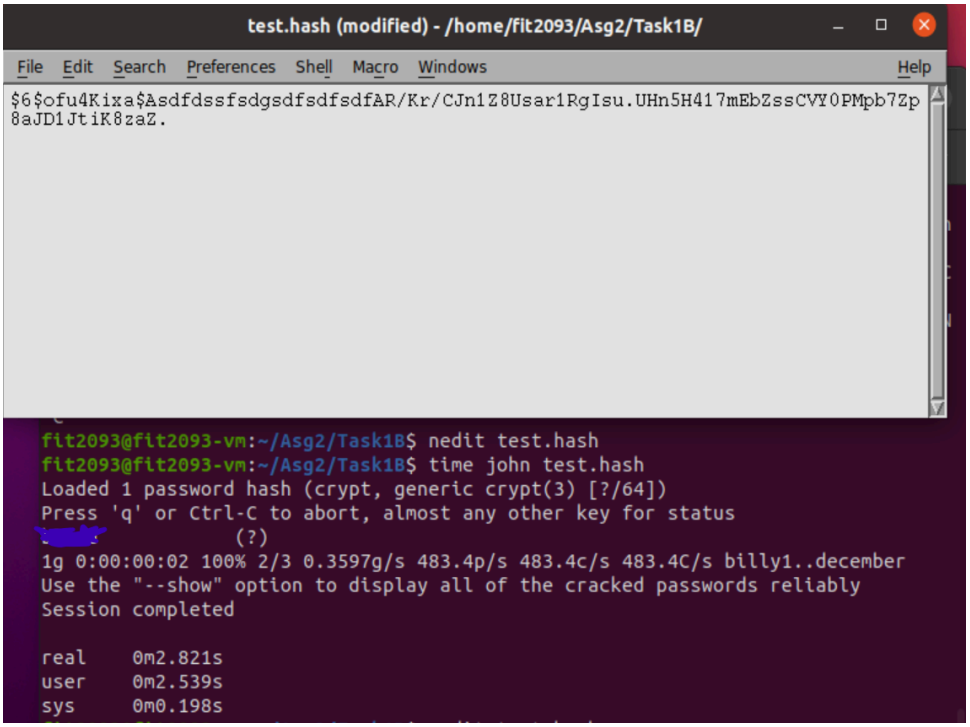
After running john the ripper as `time john <hash file>`, the file of `john.pot` (result) is located at `~/snap/john-the-ripper/<number>/.john`, <number> may vary.

- There are **four** password hashes in the given file, which can be downloaded from the Moodle Quiz. The four password hashes were generated[1] with the command `mkpasswd`. The file can be downloaded from Moodle Quiz. The file format is as shown below:

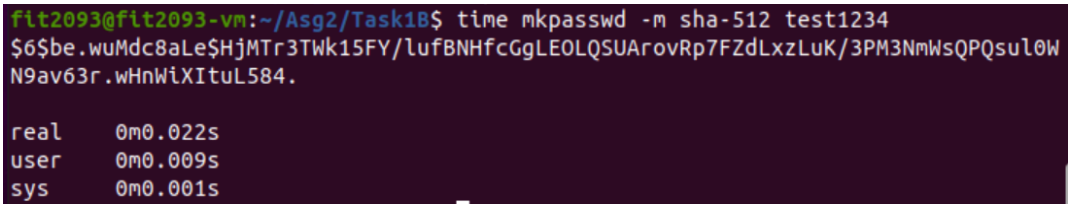
  SHA-512 Default = <hash data using SHA-512 default number of rounds>
  1000 Rounds = <hash data using SHA-512 and 1000 rounds>
  10000 Rounds = <hash data using SHA-512 and 10000 rounds>
  SHA-256 Default = <hash data using SHA-256 default number of rounds>

  Copy each of the four <hash data>, starting with the $ character and until the end of the line into a separate text file using a text editor, to create four files, one file for each of the four methods (see example screenshot below, which shows the contents one of the four files, called test.hash). Use the John the Ripper tool to time how long it takes to find the password from each of the four hash files by a search through the built in password dictionary of John, using the command **`time john test.hash`**

[1] See this page for more information on the the crypt function used in the mkpasswd command of Ubuntu Linux for password hashing, including the default number of rounds: https://manpages.ubuntu.com/manpages/bionic/man3/crypt.3.html



- Create and measure the time for a single password hashing using command **`time mkpasswd -m sha-512 <password>`** in the VM:
  - With **`sha-512`** and default no. of rounds (5000)
  - With **`sha-512`** and 1000 of rounds
  - With **`sha-512`** and 10000 rounds
  - With **`sha-256`** and default no. of rounds (5000)



- In the Task 1b section of your **Task 1 report**, include

  (1) Your results for the above four hash function methods with
  - the screen captures of the time used by John the Ripper to find the password using a brute force search through its default dictionary,
  - your screen capture of the measured **`user`** time taken to compute a single hash for each of the four types using mkpasswd. This measures how long a server would take to verify one login.

  (2) your discussion and comparison of the differences among all four hashing methods. Use 'man mkpasswd' to learn about adding salt, setting the number of rounds, and choosing hash size. Also, estimate how long it would take to brute force a dictionary of 500 million passwords for each method.

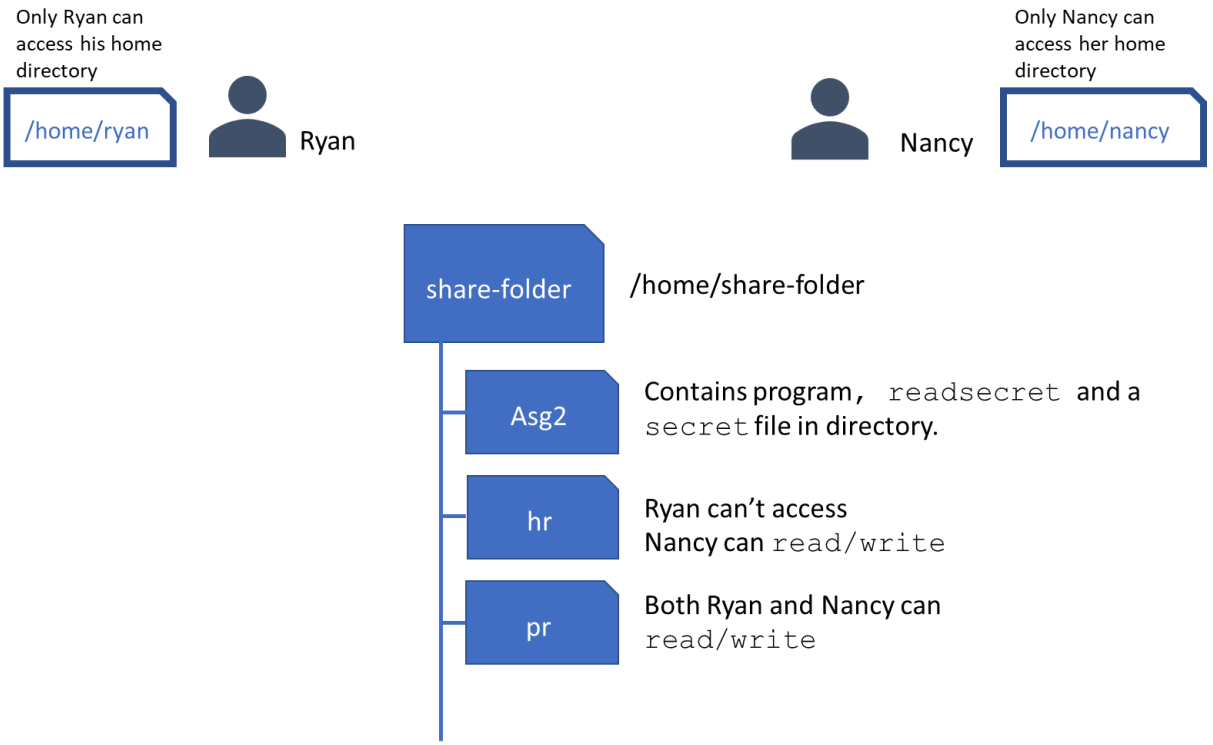
  (3) your recommendation of which method should be used for password hashing and your reasoning based on usability and security considerations.

Submission: Submit your Task 1 report as a PDF file at the Moodle Assessment Page Asg2 submission link.

Task 2: Access Control

In this task, you will assume the role of a system administrator and your task is to configure a folder, `share-folder`, and other subfolders under it. You can use your VM and login `fit2093` as a sudoer. According to the below diagram, you have to set up the following:

1. Create `share-folder` owned by `fit2093` (see **Task 2b**)
2. Create two user groups, namely `hr` & `pr` for two departments Human Resources (HR) and Public Relations (PR), respectively. (see **Task 2a**)
3. Each user group has their own directories, `hr` and `pr` respectively, and their group members can access their own directory. As the HR department saves sensitive private information, its directory is strictly restricted to its group members. However, PR is to maintain the company's public relations directory and allow both HR and PR members to access the company's news archive stored in the pr directory. (see **Task 2a**)
4. Any user can read the contents of the `secret.txt` file in the `directory` of `Asg2` by running the program `readsecret`. However, no user except `fit2093` can modify the `secret.txt` file or access it directly. (see **Task 2c**).



Task 2a) (2% of unit marks) Login as `fit2093`, who is an administrator with sudo rights to create two user groups, `hr` & `pr` and two new `users`, namely `ryan` and `nancy`, who each have their home directory, called `/home/[username]` (e.g. `/home/nancy`).

Use command `useradd` to add `nancy` into **both** the groups `hr` **and** `pr`, and add `ryan` only into the group `pr`.

In your report, you should
(1) Screen capture and explain your steps of creating the two users and adding them into the corresponding groups.
(2) Screen capture and explain the contents of the file `/etc/group` to show that users are added to the corresponding groups

Hints:

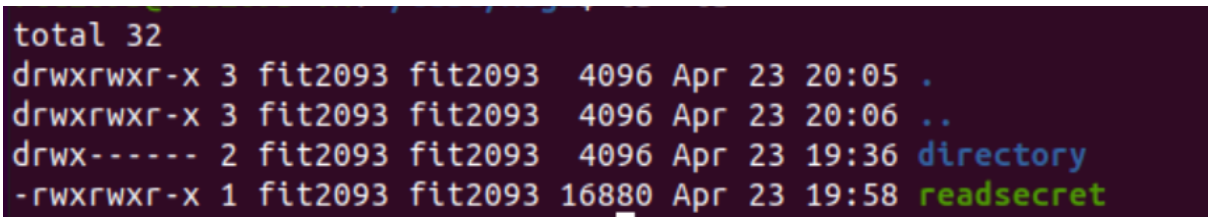
1. To remove a user, you can use the command "`sudo userdel -r [username]`")
2. To set a user's primary group or delete a user from a group, you may find useful info from https://linux.die.net/man/8/usermod

Task 2b) (5% of unit marks) Continue to login as `fit2093` to create the share-folder and then two subfolders within it, named pr and hr. Users in the pr group should only have read/write access to the pr folder, and users in the hr group should only have read/write access to the hr folder. Restrict access for all other users (i.e., unless specified, other users should not be able to read/write/execute these folders). To demonstrate the configurations have been completed properly, you have to login as `nancy` to create a file, `hr.txt`, in `/home/share-folder/hr` and only `hr` group users can modify that file whereas users in `pr` cannot access it. Then, you have to login as `ryan` to create a file, `pr.txt`, in `/home/share-folder/pr` and both `ryan` & `nancy` can modify that file.

In your report, you should:
(1) Screen capture and explain your steps of creating `share-folder` as well as two subfolders with setting user and usergroup for each folder.
(2) Screen capture and explain how to set permission rights on subfolders / usergroups such that `hr` group users **`nancy`** can access both `hr` & `pr` subfolders while `pr` group user `ryan` can access the `pr` subfolder only.

Hint: assigning a group to a directory, you may find command `chgrp` useful. Information is available by `man chgrp` in VM command line or https://linux.die.net/man/1/chgrp

Task 2c) (3% of unit) Login as `fit2093` in VM `to` download a tar file from Moodle (`readsecret_x86.tar.gz` for Windows computers or Intel-based Mac and `readsecret_m1.tar.gz` for Mac M1/M2 computers). Copy the file into `/home/share-folder/` and run `tar -zxvf readsecret_x86.tar.gz` (or `tar -zxvf readsecret_m1.tar.gz` for Mac M1/M2). You should now see a folder `Asg2` and inside the folder, the below contents. Appropriate permission may be set to `Asg2` for other users to run `readsecret`.



The contents include

- executable file, `readsecret`
- A directory, namely `directory`, containing a file `secret.txt`

As `fit2093`, you have sudo privilege to set owner and group to fit2093 on `directory`, `secret.txt` and `readsecret` as well as access control as shown in the screenshot above before implementing your tasks as below.

Your tasks are to configure the system to fulfil the following requirements

1. All users except `fit2093` can't directly access `directory` and the file in it.
2. All users can read the file `secret.txt` by running program `readsecret`, using the command
   `./readsecret directory/secret.txt`

In your report, should include:
(1) screen capture and explanation of the access rights on `directory`, `secret.txt` and `readsecret`.
(2) screen capture and explanation of post-configuration to show that users `ryan` or `nancy` can't access secret.txt directly but can read the file by using the given command in requirement 2. above.

Submission: Submit your Task 2 report as a PDF file at the Moodle Assessment Page Asg2 submission link.

WARNING (Academic integrity): It is an academic requirement that your submitted work be original. Zero marks will be awarded for the whole submission if there is any evidence of plagiarism or contract cheating (i.e. paying another person to complete the assessment task). It is fine to use code or other material from various sources in your report. However, any material that you obtain from some source (e.g. website, book, paper, article) **must be cited** in the appropriate place in your report **and listed in the references section** of your report. Please also note that students must not work on this assignment with members of other assignment groups, and significant similarities between assignments submitted by different groups (other than those due to the same cited starting source code / dataset) will be investigated for evidence of plagiarism.

REMARK (Guidelines on Use of AI tools in the Assignment): ChatGPT or other AI tools may be used for study purposes, to learn about your topic, and to develop your assignment. However, similar to citation requirements for other references (see "Academic Integrity" statement above), you **must include a clear declaration of all generative AI tools used** (e.g. ChatGPT, DALL-E, Grammarly, voice-to-text), **how and where you have used them**. In particular, you should be aware that output of AI tools may not be factually correct and you should therefore critically evaluate the output generated by such tools for claim accuracy and appropriateness to the topic, using reliable sources, before incorporating such output in your assignment (e.g. an example declaration may be: 'ChatGPT was used to generate an initial structure for the Introduction and Conclusion. I then edited this to correct factual inaccuracies, add citations to support claims, and strengthen the connection to my chosen topic and the ideas from other references that I referred to').

Where to get help

What can you get help for?

English language skills

if you don't feel confident with your English.

- Talk to English Connect: https://www.monash.edu/english-connect

Study skills

If you feel like you just don't have enough time to do everything you need to, maybe you just need a new approach

- Talk to an academic skills advisor: https://www.monash.edu/learnhq/consultations

Things are just really scary right now

Everyone needs to talk to someone at some point in their life, no judgement here.

- Talk to a counsellor: https://www.monash.edu/health/counselling/appointments (friendly, approachable, confidential, free)

Things in the unit don't make sense

Even if you're not quite sure what to ask about, if you're not sure you won't be alone, it's always better to ask.

- Ask in the forums or email your tutor:

  Teaching team: https://lms.monash.edu/course/view.php?id=155649&section=1

  Consultation: https://lms.monash.edu/mod/resource/view.php?id=11630825

I don't know what I need

Everyone at Monash University is here to help you. If things are tough now they won't magically get better by themselves. Even if you don't exactly know, come and talk with us and we'll figure it out. We can either help you ourselves or at least point you in the right direction.

Change log

All changes to the assignment will be listed here with the time of the change (in Malaysia time):

- **6 May 2024**: v1 of specs released.
- **9 May 2024:** v2 with correction
    - p.9: “`ryan` and `nancy`” is replaced by “**`nancy`**”.